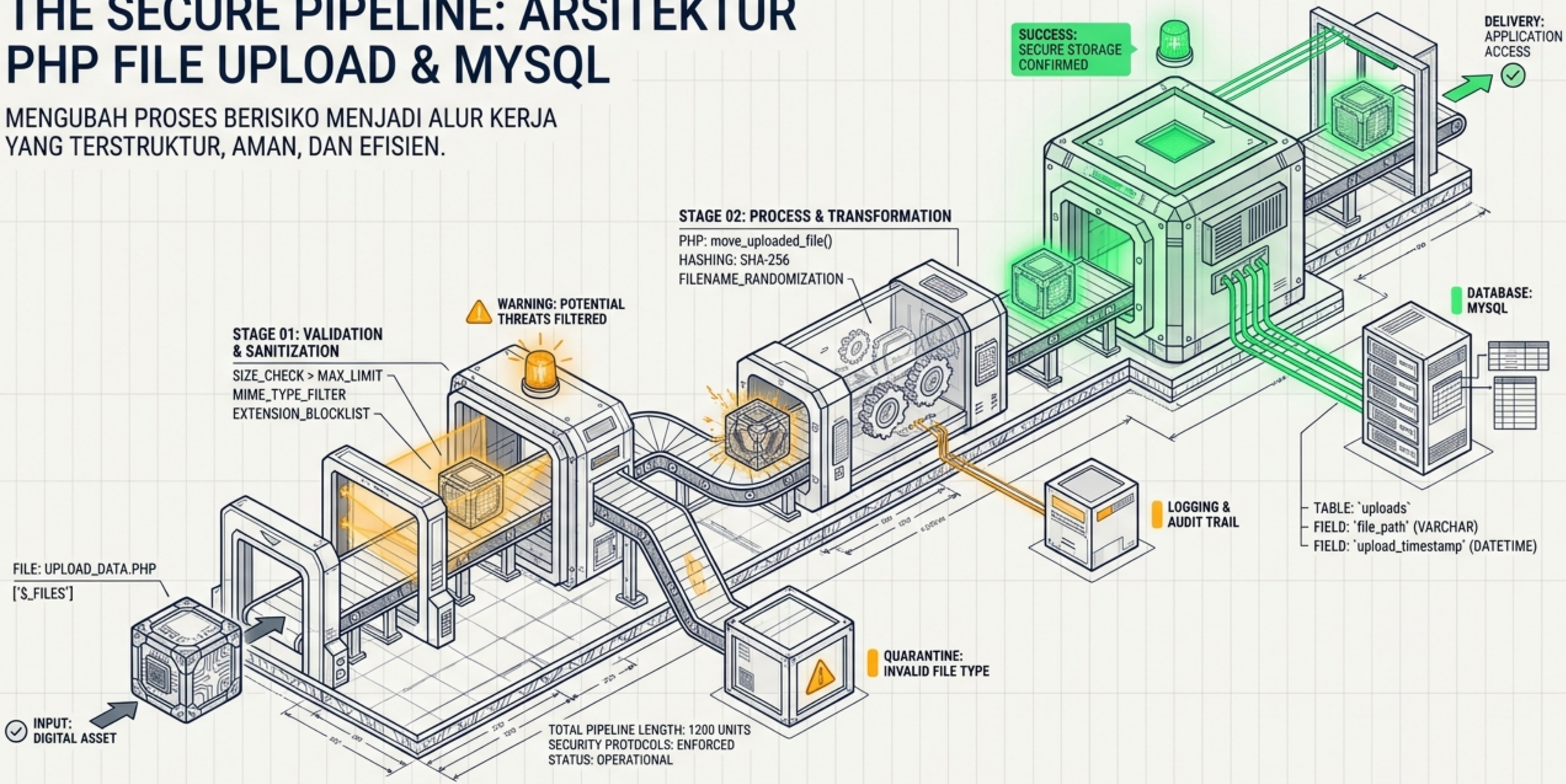
THE SECURE PIPELINE: ARSITEKTUR PHP FILE UPLOAD & MYSQL

MENGUBAH PROSES BERISIKO MENJADI ALUR KERJA
YANG TERSTRUKTUR, AMAN, DAN EFISIEN.



Gemini Notebook

Mengapa Web Membutuhkan Upload File?



Identitas Digital

Pengguna mengunggah foto profil (Avatar) untuk personalisasi akun.



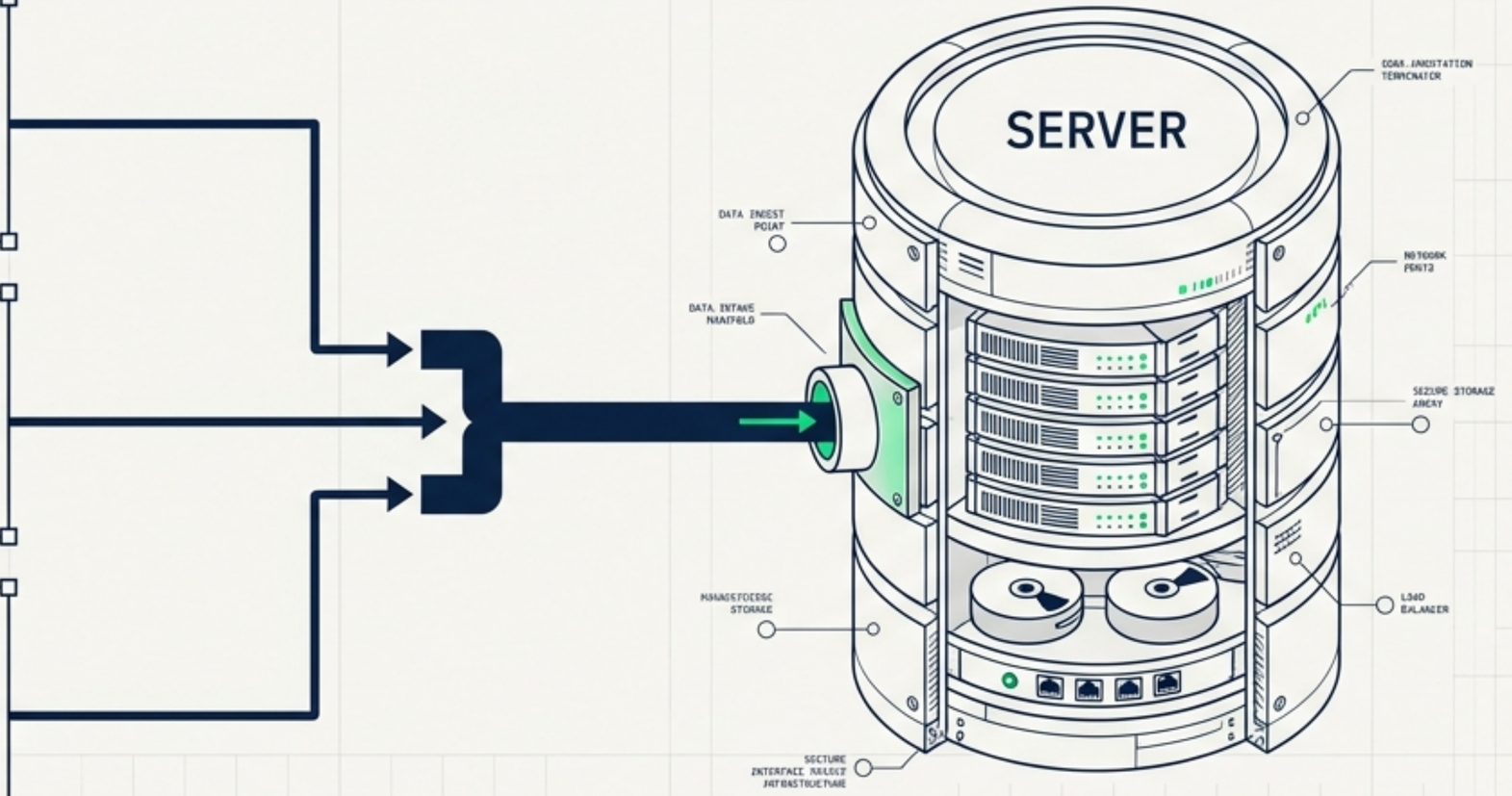
Kolaborasi Dokumen

Pertukaran berkas PDF, laporan, atau lembar kerja dalam sistem manajemen.



Distribusi Media

Berbagi gambar atau video dalam galeri atau platform sosial.



Web modern bukan hanya tentang membaca data, melainkan memindahkan aset fisik dari dunia pengguna ke dalam infrastruktur server kita.

Gemini Notebook

Mitos Database: Fisik vs. Alamat

Mengapa kita tidak menjejalkan file fisik ke dalam MySQL?

	Menyimpan Fisik (BLOB)	Menyimpan Alamat (File Path)
Beban Storage	Database membengkak secara eksponensial.	Database sangat ringan (hanya teks).
Kecepatan Akses	Lambat (membutuhkan konversi biner pada setiap permintaan).	Sangat Cepat (langsung dilayani oleh web server).
Kompleksitas Backup	Sangat berat, lama, dan berisiko korup saat pemulihan.	Sederhana (backup file fisik dan database dilakukan terpisah).

KESIMPULAN: Simpan file fisiknya di folder server. Simpan alamatnya di database.

Gemini Notebook

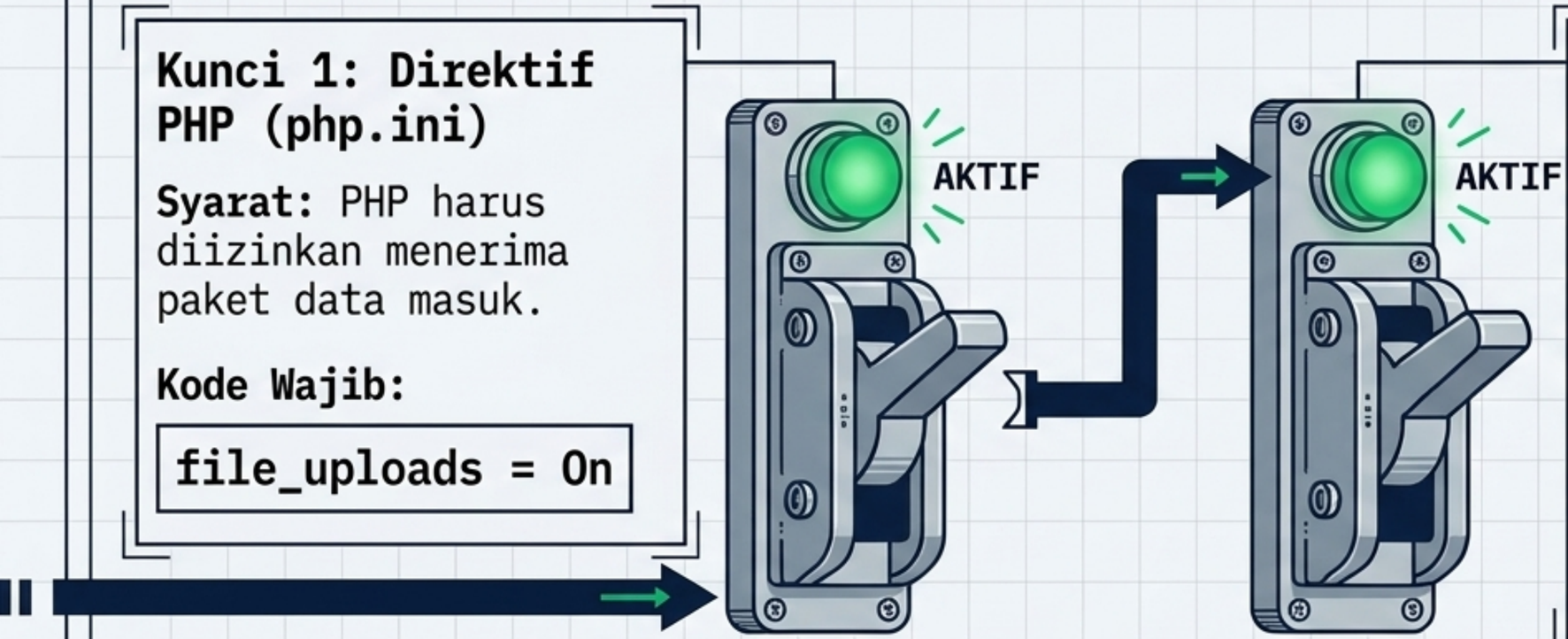
Para Penjaga Gerbang: Konfigurasi Lingkungan

Kunci 1: Direktif PHP (php.ini)

Syarat: PHP harus diizinkan menerima paket data masuk.

Kode Wajib:

`file_uploads = On`



Kunci 2: Hak Akses Server (Permissions)

Syarat: Folder tujuan penyimpanan (misal: uploads/) wajib berstatus writable (bisa ditulisi).

Sistem Unix:

`chmod 777` atau `775`

Perhatian: Tanpa kedua kunci ini terbuka, kode PHP se-sempurna apa pun akan secara otomatis menolak proses file upload di tingkat server.

Gemini Notebook

Anatomi HTML: Pengemasan Paket Data

```
<form action='upload.php' method='POST'
  enctype='multipart/form-data'>
  Pilih gambar:
  <input type='file' name='fileToUpload'>
  <input type='submit' value='Upload'>
</form>
```

`method='POST'`

Wajib. Paket file biner terlalu besar untuk dikirim melalui metode GET (URL).

`enctype='multipart/form-data'`

Lakban khusus file. Memecah file menjadi beberapa bagian biner agar bisa ditransmisikan. Tanpa ini, hanya nama file (string) yang terkirim.

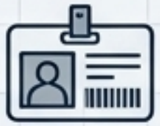
`type='file'`

Memicu browser web untuk membuka jendela File Explorer native milik pengguna.

Gemini Notebook

Membedah Superglobal $_FILES (Manifes Pengiriman)

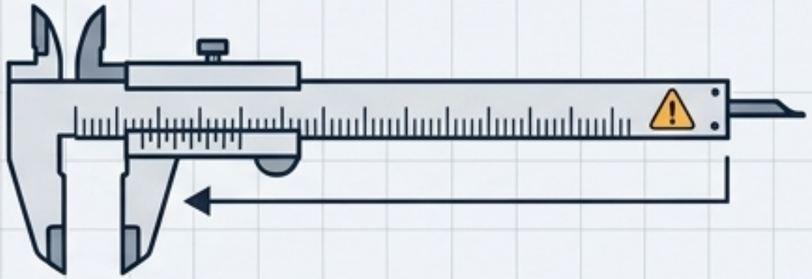
Saat paket tiba, PHP otomatis membuat array 2-dimensi berdasarkan atribut ‘name’ dari form HTML (contoh: `$_FILES['fileToUpload']`).

ARRAY KEY		DEFINITION & SPECIFICATION
['name']		**Identitas Publik:** Nama asli file dari komputer pengguna (misal: foto.jpg).
['type']		**Label Ekstensi:** MIME type dari file (misal: image/jpeg).
['size']		**Timbangan:** Ukuran file dalam satuan murni bytes.
['tmp_name']		**Ruang Karantina:** Lokasi path sementara di dalam server sebelum diverifikasi dan dipindahkan.
['error']		**Status Kode:** Nilai 0 berarti sukses, angka lain berarti ada kendala transmisi.

Gemini Notebook

Kotak Perkakas Eksekusi PHP

Fungsi Pemeriksa (The Inspectors)



`is_uploaded_file()`

Memastikan file benar-benar datang dari rute HTTP POST, bukan file lokal server yang diretas.

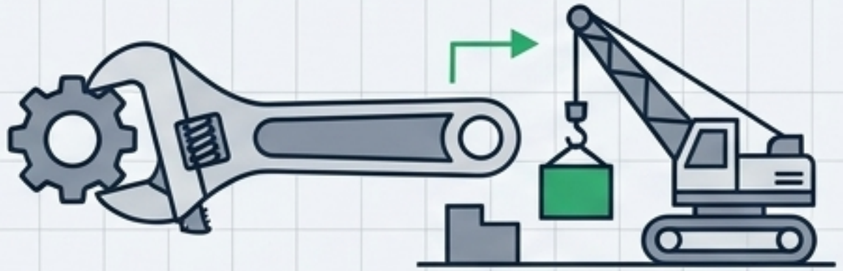
`file_exists()`

Mengecek apakah nama file sudah ada di folder tujuan untuk mencegah tertimpa (overwrite).

`getimagesize()`

Inspeksi struktural mendalam untuk memastikan file adalah gambar asli, bukan malware yang menyamar.

Fungsi Manipulator (The Workers)



`basename()`

Mengambil murni nama file dari sebuah untaian path yang panjang.

`pathinfo()`

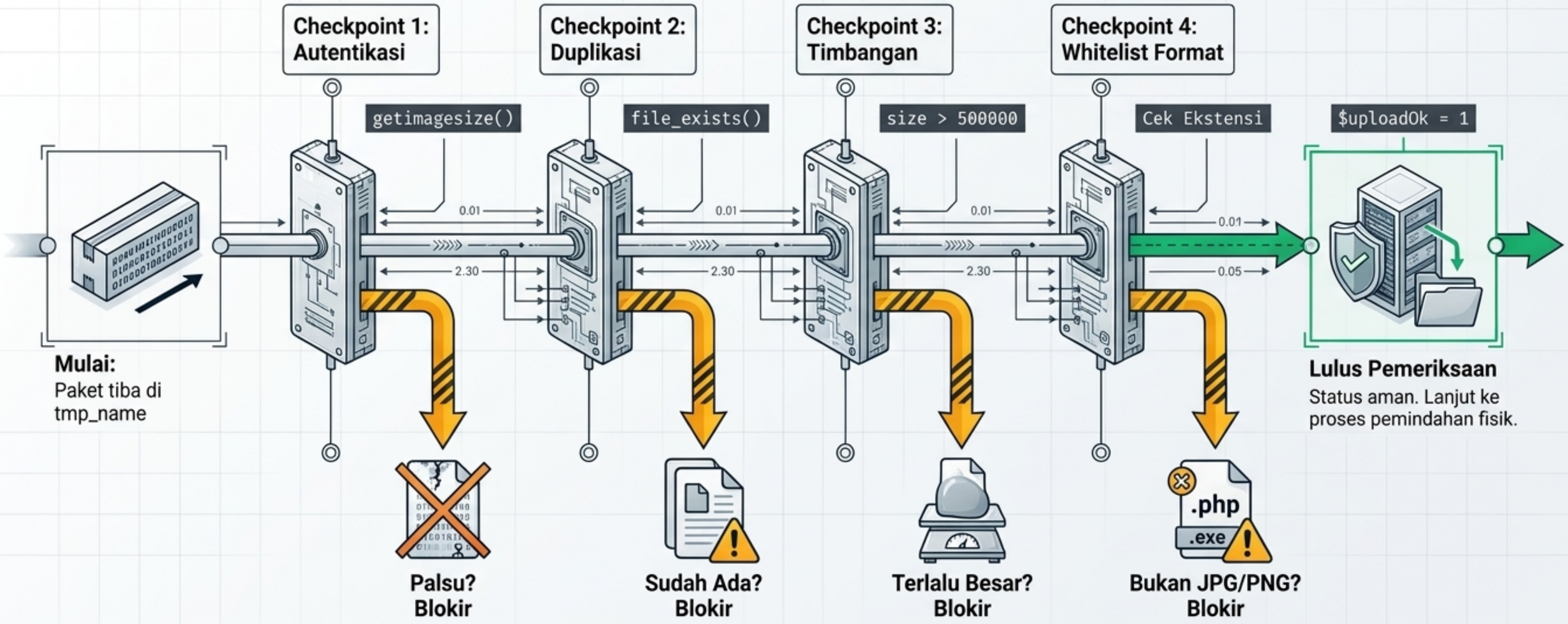
Mengekstrak tipe ekstensi file secara akurat menggunakan flag `` `PATHINFO_EXTENSION` ``.

`move_uploaded_file()`

Alat berat yang memindahkan file secara aman dari ruang karantina ke gudang penyimpanan utama.

Gemini Notebook

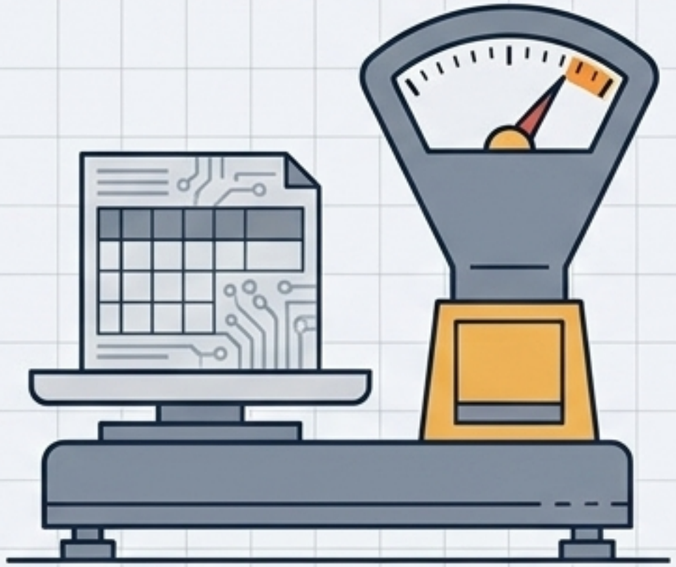
Arsitektur Keamanan: Titik Pemeriksaan



Gemini Notebook

Implementasi Filter Spesifik

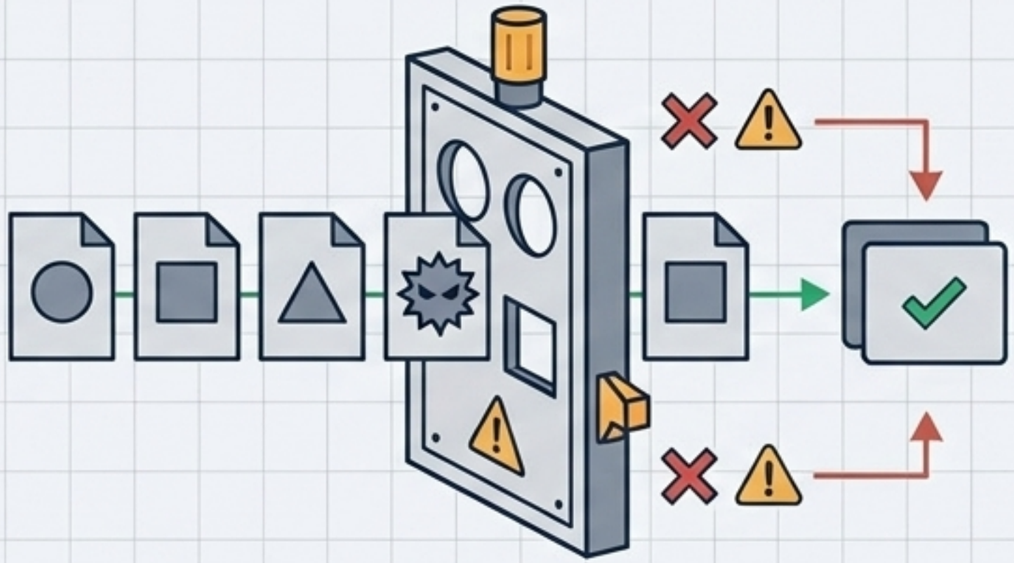
Pembatasan Ukuran (Size Limit)



Mencegah server kehabisan kapasitas storage (mitigasi serangan DDoS).

```
if ($_FILES['fileToUpload']['size'] > 500000) {
  echo 'File terlalu besar.';
  $uploadOk = 0;
}
```

Pembatasan Tipe (Whitelist Format)



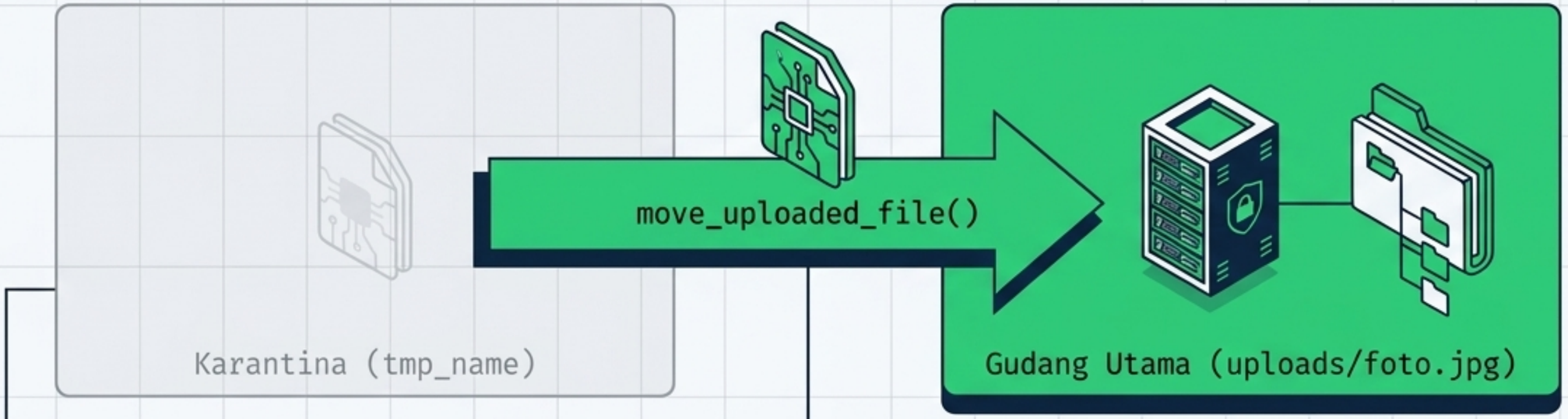
Memblokir eksekusi malware yang bersembunyi (misal: ekstensi .php atau .exe).

```
if($ext != 'jpg' && $ext != 'png' && $ext != 'jpeg') {
  echo 'Hanya JPG, JPEG, & PNG yang diizinkan.';
  $uploadOk = 0;
}
```

Gemini Notebook

Lampu Hijau: Pemindahan File

Setelah semua filter dilewati, fungsi **move_uploaded_file()** mengambil alih. Ini adalah satu-satunya cara yang diakui aman untuk memindahkan file upload di PHP.



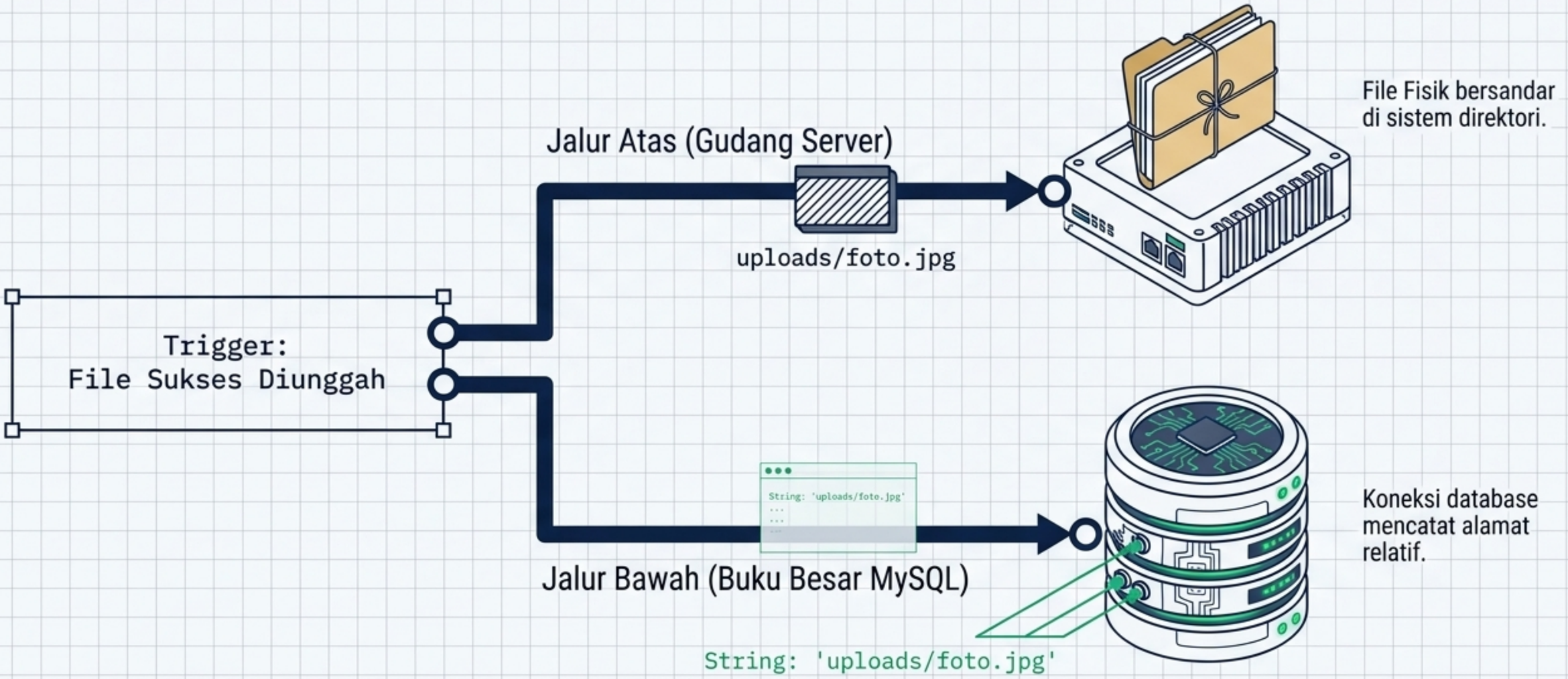

```php
if ($uploadOk == 1) {
   if (move_uploaded_file($_FILES['file']['tmp_name'], $target_file)) {
      echo 'File ' . basename($_FILES['file']['name']) . ' berhasil diunggah.';
   }
}
```

Catatan: Variabel $target_file adalah gabungan (*concatenation*) dari nama folder tujuan dan nama asli file.

Gemini Notebook

Aksi Paralel: Pemisahan Fisik dan Metadata

Kita TIDAK mengirim file fisiknya ke dalam database. Kita hanya mengambil string "alamat penunjuk jalan" untuk dicatat.



Gemini Notebook

Brankas Data: Eksekusi INSERT INTO yang Aman

Menyimpan file path ke tabel database wajib menggunakan Prepared Statements agar kebal dari serangan SQL Injection yang disisipkan melalui nama file.

Siapkan Query (Template)

```
$stmt = $conn->prepare(
  'INSERT INTO gallery (file_path)
  VALUES (?)');
```

Tanda tanya (?) bertindak sebagai cangkang kosong yang aman.

Ikat Parameter (Mengamankan String)

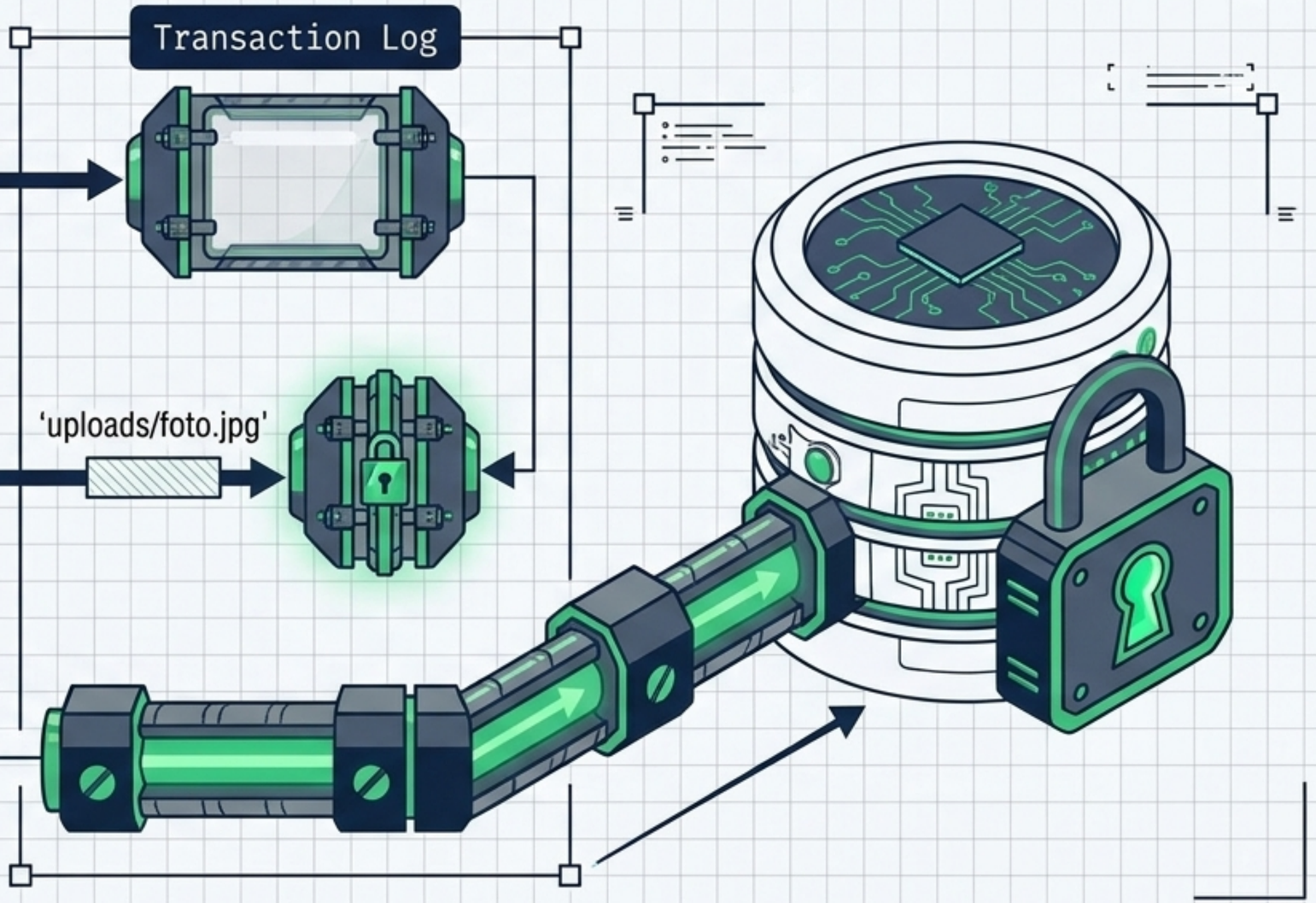
```
$stmt->bind_param('s', $path);
```

Mengunci string teks path ('uploads/foto.jpg') ke dalam cangkang kosong tadi. Karakter jahat akan dinetralkan.

Eksekusi

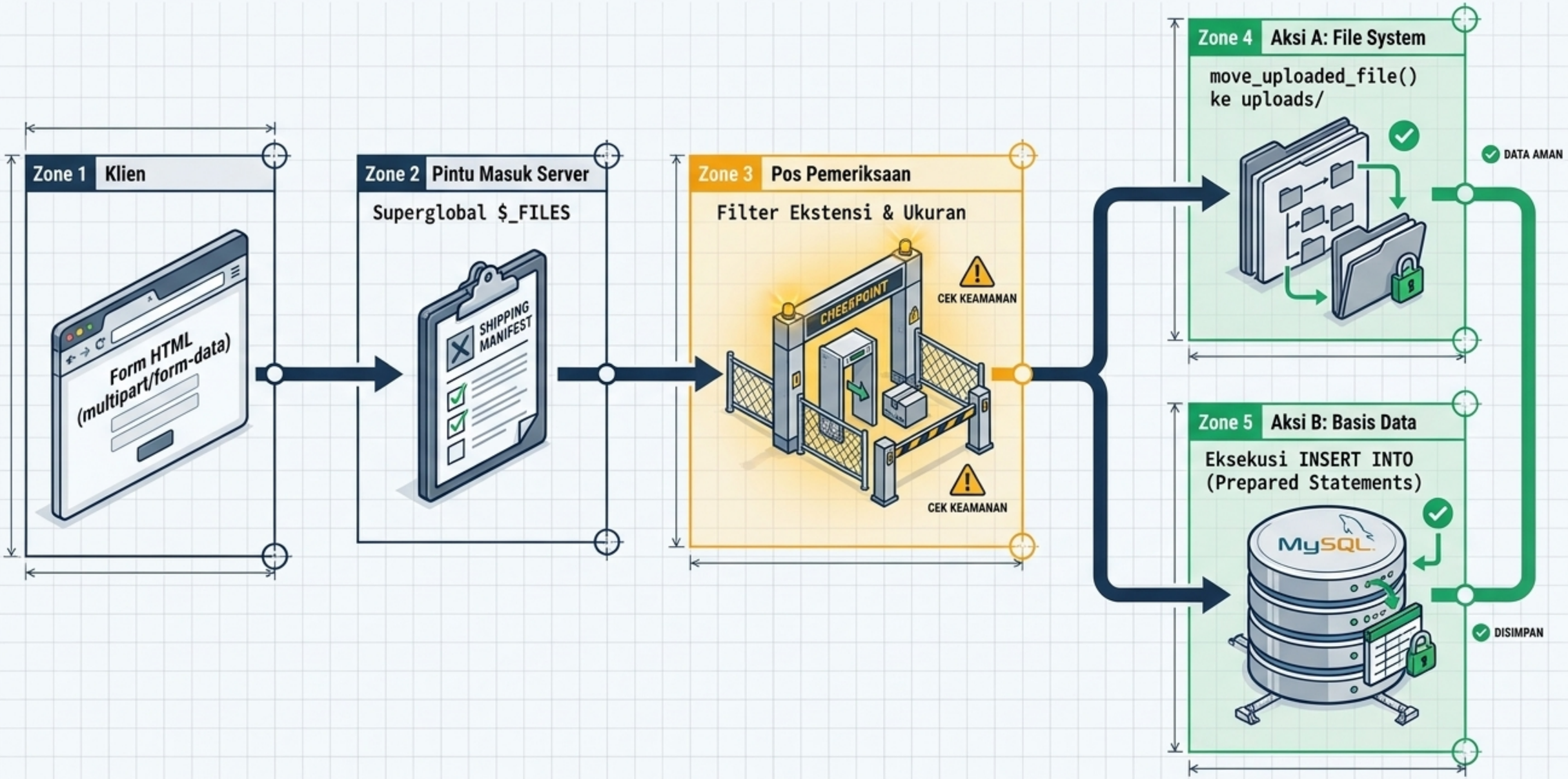
```
$stmt->execute();
```

Perintah divalidasi dan dicatat permanen ke dalam tabel.



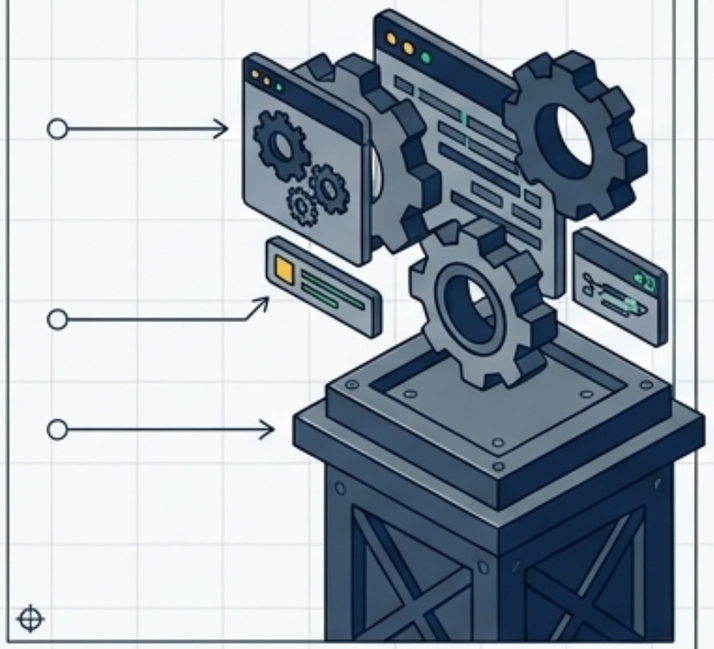
Gemini Notebook

End-to-End: Pipa Saluran Data (The Blueprint)



Gemini Notebook

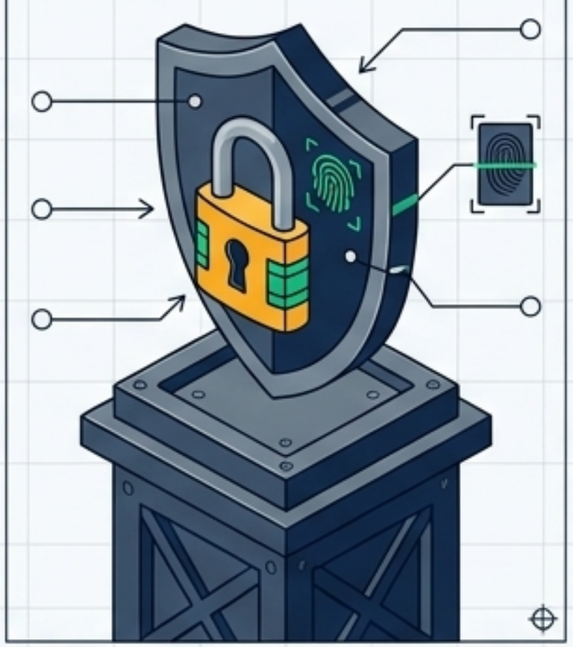
Tiga Pilar File Upload yang Aman



Pillar 1

Konfigurasi Gerbang

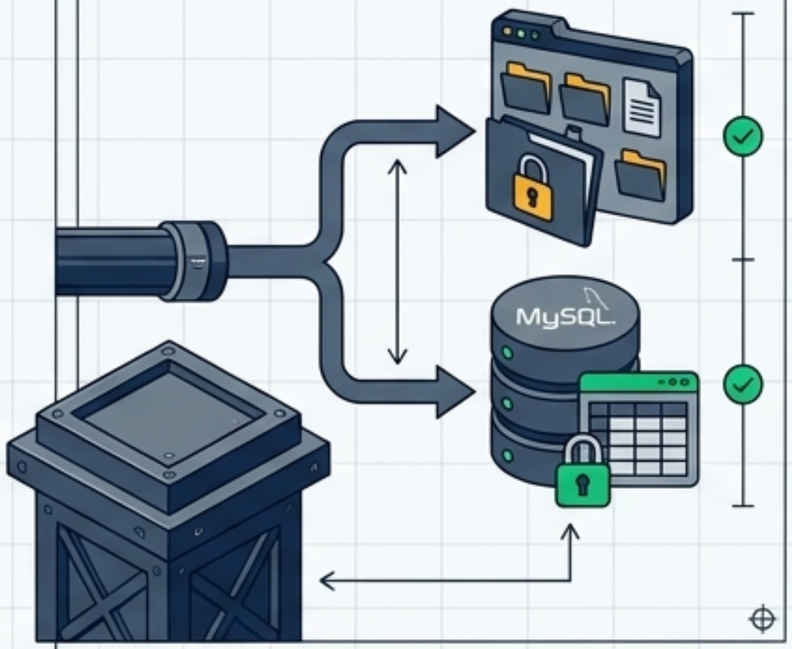
Pastikan php.ini mengizinkan proses upload dan folder tujuan di server memiliki hak akses writable yang tepat.



Pilar 2

Zero Trust Validation

Jangan pernah percaya input pengguna. Selalu manfaatkan `$_FILES`, batasi batas maksimal ukuran, dan gunakan whitelist ekstensi secara ketat.



Pilar 3

Arsitektur Paralel

Simpan wujud fisik file di dalam sistem direktori server, dan cukup simpan file path (alamatnya) secara aman di tabel MySQL.

Gemini Notebook